

Zanzirangi Production Readiness Assessment

Audit date	2026-10-01
Revision	main @ 2379f82 + 128 uncommitted changes
Scope	Repository only. No live server, hosting panel, DNS or production database was accessed.
Companion	ZANZIRANGI_PROJECT_BRIEF.md

Verdict: PARTIALLY READY

The application code (CMS, API, auth, data layer, error handling) is close to production quality. The **operational and business-critical prerequisites are not met**: the booking enquiry form is non-functional, there is no verified backup, the deployed code is not under version control, no live deployment has been evidenced, and public structured data contains unverified facts. Resolving the P0 blockers below would move the project to **PRODUCTION READY WITH RISKS**.

1. Scorecard

Area	Rating	Evidence	Blocking?
Functionality	Partial	Full CMS (21 admin views) and public site implemented; booking enquiry does not transmit (src/components/BookingModal.tsx:217-224); no 404 page	Yes
Security (application)	Good	bcrypt-12, JWT + server revocation, server-side RBAC, login rate limit, upload validation, API headers, prod env fail-fast, npm audit 0 vulns	No
Security (operational)	Weak	Infra identifiers in committed docs; dev wired to remote DB; token-printing script; hash-bearing snapshot files	Yes
Infrastructure	Unverified	Hostinger design evident in code; domain/SSL/DNS/Node version not verifiable	Yes (verification)
Deployment	Partial	Reproducible build + secret-scanning packager exist; process manual; docs inconsistent; GitHub Pages workflow still active on main	Partly
Version control / release	Not ready	128 uncommitted changes incl. migration 003 and 9 admin modules; no tags; version 1.0.0 not maintained	Yes
Database	Partial	Parameterised queries, pooled, retry; manual migrations, no runner; migration 003 MariaDB-specific syntax	Partly
Backup & DR	Not implemented	No automated DB/media backup; platform backups unverified; restore untested	Yes
Monitoring	Minimal	/api/health only; no uptime monitor, alerting or error tracking	No (P1)
Error handling	Good	JSON 404/error handler, production message masking, graceful shutdown, DB reconnect	No
Documentation	Partial	40+ docs, but README obsolete and deployment docs contradictory	No
QA	Partial	Build passes; tsc fails (13 errors in scripts/); no automated tests in CI; API test scripts only runnable against a live DB	No (P2)
SEO	Partial	Strong technical SEO; inaccurate location/phone/ratings in JSON-LD and 1 lms.txt	Yes (accuracy)

Area	Rating	Evidence	Blocking?
Performance	● Partial	1.73 MB JS single chunk incl. admin; 5.5 MB PNG in <code>public/</code> ; no image pipeline	No (P2)
Client handover	● Not ready	Ownership of domain/hosting/accounts unverified; no runbook/admin guide	No (pre-handover)

2. Go-Live Blockers (P0)

#	Blocker	Evidence	Exit criterion
1	Booking enquiry not sent	<code>BookingModal.tsx:217-224</code>	A test enquiry is stored and staff are notified, or the form is removed and replaced by explicit WhatsApp/chat CTAs
2	Uncommitted production code	<code>git status</code> : 90 modified, 38 untracked	Working tree clean; release tagged; deploy zip built from the tag
3	Dev/test wired to non-local DB; destructive scripts	<code>.env</code> / <code>.env.local</code> DB host non-local; <code>scripts/restore-exact-baseline.ts:53</code> TRUNCATE; CRUD test suites	Separate dev/test DB; production credentials only in hPanel; scripts refuse to run against production host
4	No verified backups	§15 of Brief	Daily DB + media backup confirmed (Hostinger panel screenshot or scripted dump) and one successful restore drill to a non-production DB
5	Inaccurate public facts	Map = Bwejuu (<code>propertyConfig.ts:21-22</code>) vs JSON-LD = Kizimkazi; placeholder phone in <code>index.html</code> , <code>llms.txt</code> ; unverified AggregateRating	Owner-confirmed address, coordinates, phone, rating source; all sources consistent
6	Infrastructure identifiers in docs	DB username/name/host, developer IP, password-length hints in <code>docs/</code> and root <code>HOSTINGER_*.md</code>	Docs redacted; DB password rotated; Remote MySQL access restricted/disabled
7	No evidenced live deployment	All test reports target localhost or remote DB from developer PC	Documented deployment to <code>zanzirangihouse.com</code> with smoke test (see §4)

3. High Priority (P1) — before or immediately after launch

- Disable `.github/workflows/deploy.yml` (GitHub Pages) and remove `vercel.json` if obsolete — they publish a static copy without the API.
- Confirm DB engine (MySQL vs MariaDB) and apply migration 003 safely; add a versioned migration runner.
- External uptime monitoring on `https://zanzirangihouse.com/api/health` with alerts.
- Error tracking (server + client).
- Notification to staff when a chat enters `WAITING_HUMAN`.
- Remove `scripts/print-superadmin-token.ts`; securely dispose of `backups/*.json` snapshots containing password hashes when no longer needed.
- Rate-limit public `/api/support/*` endpoints.

4. Production Verification Checklist (to be executed on the live host)

Check	Expected	Status
<code>https://zanzirangihouse.com</code> loads over valid TLS; HTTP → HTTPS redirect	200, valid certificate	NOT VERIFIED

Check	Expected	Status
<code>www</code> → apex canonical redirect	single canonical host	NOT VERIFIED
<code>GET /api/health</code>	<code>200</code> , <code>database.connected: true</code> , <code>provider: mysql</code>	NOT VERIFIED
Deep link <code>/villas</code>	pre-rendered HTML, 200	NOT VERIFIED
Unknown path <code>/does-not-exist</code>	currently 200 shell (known gap)	NOT VERIFIED
<code>/robots.txt</code> , <code>/sitemap.xml</code> , <code>/llms.txt</code>	served	NOT VERIFIED
Admin login, edit content, change visible on site	works	NOT VERIFIED
Media upload persists across a redeploy	file still served	NOT VERIFIED
Upload path is <code>zanzirangi-media</code> (not <code>./uploads</code> fallback)	startup log shows persistent path	NOT VERIFIED
Chat: visitor message → admin inbox → admin reply visible to visitor	works	NOT VERIFIED
Login rate limit triggers after 10 failures	429	NOT VERIFIED
Env: <code>NODE_ENV=production</code> , strong <code>JWT_SECRET</code> , <code>DB_HOST=127.0.0.1</code> , <code>CORS_ORIGIN</code> exact origin	set in hPanel	NOT VERIFIED
Node version on host	≥ 20 (22 recommended)	NOT VERIFIED
Backups enabled and restorable	yes	NOT VERIFIED

5. Evidence From This Audit (commands executed 2026-10-01)

Command	Result
<code>npx tsc --noEmit</code>	Exit 2 — 13 errors , all in <code>scripts/</code> (<code>run-cms-coverage-migration.ts</code> ×11, <code>test-cms-pipeline-hardening.ts</code> ×1, <code>test-full-cms-coverage.ts</code> ×1)
<code>npx vite build</code> (to scratch dir)	Success — JS 1,729 kB (535 kB gzip), CSS 126 kB, chunk-size warning
<code>npm audit</code>	0 vulnerabilities
API/CRUD test suites	Not executed — would write to the configured (non-local) database

6. Residual Risks Accepted Under "Ready With Risks" (if P0 resolved)

Risk	Rationale for acceptance	Mitigation timeline
JWT in localStorage	XSS surface currently small (React escaping; no user HTML rendering)	P2
No CSP on HTML pages	Same as above	P2
Single JS bundle 1.7 MB	Functional; affects performance only	P2
No automated test suite in CI	Manual smoke test per release	P2

Risk	Rationale for acceptance	Mitigation timeline
Manual deployment	Low release frequency	P3
No staging	Use a Hostinger subdomain later	P3